INSEGUS · UNIVERSIDAD DE SEVILLA

PAI-3. VulnaWeb
Auditoría de Seguridad en Sistemas Informáticos y Análisis de Vulnerabilidades en una Universidad Pública

Seguridad en Sistemas Informáticos e Internet (SSII)

Security Team · Grupo 20

Francisco Javier Rodríguez Martín

Ricardo Guisado Arenas

Álvaro Morillo Navajas

Grado en Ingeniería Informática · Curso 2026-2027 · Noviembre de 2026

Índice

1. Resumen ejecutivo

2. Auditoría de sistemas informáticos (endpoints Linux)

   2.1. Descripción del sistema y herramientas

   2.2. Plan de pruebas y resultados

   2.3. Conclusiones

3. Análisis y bastionado de navegador web

   3.1. Descripción del sistema y herramientas

   3.2. Directivas aplicadas

   3.3. Resultados y validación externa

   3.4. Conclusiones

4. Auditoría de sistema móvil (BYOD)

   4.1. Metodología y herramientas

   4.2. Resultados por checklist

   4.3. Conclusiones

5. Auditoría de sistema web

   5.1. Descripción del sistema y herramientas

   5.2. Plan de pruebas y resultados

   5.3. Conclusiones

6. Referencias

Anexos: evidencias técnicas

1. Resumen ejecutivo

El presente documento recoge la auditoría de seguridad integral encargada por INSEGUS sobre la infraestructura de una universidad pública, realizada por el Security Team (Grupo 20). El alcance abarca cuatro dominios: el bastionado de los equipos informáticos (endpoints Linux), la fortificación de los navegadores web corporativos, la auditoría de la postura de seguridad de un dispositivo móvil BYOD y el análisis dinámico de vulnerabilidades sobre las aplicaciones web. La totalidad de las pruebas se ejecutó en entornos de laboratorio controlados, sin impacto sobre sistemas en producción, y siguiendo marcos de referencia como el OWASP Top 10 2025, los CIS Benchmarks, la guía NIST SP 800-115 y el Esquema Nacional de Seguridad (ENS).

Los resultados confirman una mejora sustancial de la postura de seguridad en todos los dominios. En los endpoints Linux, el índice de bastionado de Lynis superó el umbral exigido (≥ 70) en los dos sistemas auditados. En los navegadores se desplegó un perfil corporativo mediante políticas gestionadas, validado con herramientas externas de privacidad y de TLS. En el dispositivo móvil, la puntuación de protección pasó de 38 a 88 tras subsanar los riesgos de configuración y permisos. Por último, la auditoría web demostró la trazabilidad del tráfico cifrado a través de un proxy interceptor y la explotación de tres vulnerabilidades del OWASP Top 10 2025, con su correspondiente plan de mitigación. Las evidencias técnicas completas (capturas, logs y configuraciones) se adjuntan en los anexos y en el paquete de entrega.

2. Auditoría de sistemas informáticos (endpoints Linux)

2.1. Descripción del sistema y herramientas

Para las pruebas de auditoría y endurecimiento (*hardening*) de la infraestructura base se desplegaron dos entornos virtuales independientes sobre el hipervisor Oracle VM VirtualBox: un **Endpoint 1** con Ubuntu 24.04 LTS (x86_64), configurado como estación de trabajo cliente, y un **Endpoint 2** con Debian 12 Bookworm (x86_64), configurado como servidor de infraestructura base.

Como motor central de análisis se utilizó **Lynis**, herramienta de auditoría automatizada y de código abierto para sistemas Unix. Lynis realiza un escaneo exhaustivo y no destructivo del sistema, evaluando las configuraciones frente a estándares como CIS Benchmarks e ISO 27001 y consolidando el resultado en el *Hardening Index* (escala de 0 a 100). Para garantizar la reproducibilidad y el control de versiones se aplicó una metodología de cuatro fases respaldada por instantáneas de VirtualBox: línea base (*baseline*), remediación mediante scripts de despliegue, re-auditoría y verificación del umbral (≥ 70), y empaquetado del estado final con extracción de los registros brutos (`lynis.log`, `lynis-report.dat`). Las instantáneas de ambos sistemas se recogen en el Anexo A (Fig. A.1 y A.2).

2.2. Plan de pruebas y resultados

El plan de remediación se enfocó en subsanar de forma sistemática los avisos (*warnings*) y recomendaciones (*suggestions*) detectados por Lynis tras la auditoría inicial. Las contramedidas se estructuraron en cuatro vectores de actuación:

- **Filtrado perimetral y seguridad de red:** habilitación de UFW con política restrictiva de entrada (*deny incoming*) y endurecimiento del núcleo vía `sysctl` (validación de ruta inversa frente a *IP spoofing*, `tcp_syncookies` frente a *SYN flood*, descarte de enrutamiento de origen e ignorado de *broadcast* ICMP frente a ataques de amplificación).
- **Endurecimiento del kernel y control del sistema de ficheros:** `fs.protected_symlinks` y `fs.protected_hardlinks` frente a condiciones de carrera, `kernel.kptr_restrict` y `kernel.dmesg_restrict` frente a fugas de información del núcleo, y `fs.suid_dumpable=0` para anular volcados de memoria en procesos privilegiados.
- **Fortalecimiento de autenticación (PAM):** módulo `pam_pwquality` imponiendo longitud mínima de 12 caracteres, concurrencia de mayúscula, minúscula, dígito y carácter especial, y cambio de al menos 3 caracteres respecto a claves anteriores.
- **Reducción de la superficie de ataque:** restricción de permisos de compiladores y ensambladores a *root* (`chmod 700`) y ajuste del perfil de auditoría (`custom.prf`) para descartar pruebas de hardware irrelevantes en máquinas virtuales.

La aplicación coordinada de estas contramedidas permitió elevar el índice por encima del umbral mínimo exigido en ambos sistemas (Anexo A, Fig. A.3–A.6):

Endpoint	Sistema operativo	Índice inicial	Índice final	Variación	Requisito (≥ 70)
Endpoint 1	Ubuntu 24.04 LTS	63	**73**	+10 (+15,87 %)	SUPERADO
Endpoint 2	Debian 12 Bookworm	64	**70**	+6 (+9,37 %)	SUPERADO

2.3. Conclusiones

La auditoría inicial evidenció que tanto Ubuntu 24.04 como Debian 12 presentan de forma nativa configuraciones orientadas a la interoperabilidad y la facilidad de uso, sacrificando controles esenciales como la restricción de llamadas al kernel, el filtrado perimetral por defecto o la complejidad en la autenticación local. El plan de bastionado implementado elevó sustancialmente la resiliencia de ambas plataformas sin degradar sus servicios esenciales: las contramedidas de red, la contención de memoria en espacio de usuario y la neutralización de compiladores locales cerraron los vectores habituales de intrusión y movimiento lateral, superándose en ambos casos el criterio de corte del proyecto.

3. Análisis y bastionado de navegador web

3.1. Descripción del sistema y herramientas

Para el bastionado de los navegadores del laboratorio se utilizaron **Mozilla Firefox** (v159) y **Google Chrome** (v156), ambos sobre Windows 10/11. El despliegue se realizó mediante directivas corporativas (políticas gestionadas) a nivel de sistema, con nivel obligatorio, lo que impide que el usuario final revierta las configuraciones de seguridad. Las políticas se validaron mediante las consolas internas *about:policies* (Firefox) y *chrome://policy* (Chrome), recogidas en el Anexo B (Fig. B.1 y B.2).

3.2. Directivas aplicadas

Se diseñó un perfil de seguridad centrado en la mitigación de riesgos de red, privacidad y ejecución de código. Dado que Chrome y Firefox no comparten todas las directivas, se indica el navegador al que aplica cada una:

Directiva	Navegador	Valor	Riesgo que mitiga
HttpsOnlyMode	Chrome y Firefox	force_enabled	Downgrade e interceptación (*sniffing*) en redes públicas.
ExtensionSettings	Firefox	installation_mode = blocked	Extensiones no auditadas que exfiltran datos o inyectan código.
PasswordManagerEnabled	Chrome y Firefox	false	Credenciales almacenadas en el perfil local.
BlockThirdPartyCookies / EnableTrackingProtection	Chrome / Firefox	true	Rastreo entre sitios, criptominería y *fingerprinting*.
DNSOverHTTPS	Firefox	Enabled, Locked	Espionaje o manipulación de las consultas DNS.
DisableTelemetry / DisableFirefoxStudies	Firefox	true	Envío de datos de uso y participación en estudios remotos.
SafeBrowsingProtectionLevel	Chrome	2 (mejorada)	Sitios y descargas maliciosos (phishing/malware).
AppAutoUpdate / DownloadRestrictions	Firefox / Chrome	true / 1	Vulnerabilidades conocidas y descargas peligrosas.

3.3. Resultados y validación externa

Para verificar la eficacia del bastionado se emplearon dos herramientas externas, EFF Cover Your Tracks (privacidad) y SSL Labs Client Test (red), comparando el estado antes y después en cada navegador (Anexo B, Fig. B.3–B.10):

- **EFF Cover Your Tracks:** en Chrome, el resultado pasó de *no protegido* frente al rastreo a *protección parcial*; en Firefox mejoró de *protección parcial* a *protección fuerte*, con bloqueo de anuncios y

rastreadores invisibles. En ambos la huella digital sigue siendo única, limitación inherente al motor del navegador.

- **SSL Labs Client Test:** en los dos navegadores solo se negocian TLS 1.2 y TLS 1.3, sin vulnerabilidad a CurveBall, Logjam, FREAK ni POODLE. Este resultado proviene del comportamiento por defecto de las versiones actuales; para imponerlo por política podría usarse `SSLVersionMin` (tls1.2), no aplicado en este laboratorio.

3.4. Conclusiones

El despliegue centralizado de políticas elevó el nivel de seguridad de los navegadores de forma uniforme, mitigando la interceptación de tráfico (HTTPS-only), la exposición de credenciales almacenadas y la instalación de extensiones no deseadas. Como limitaciones, la huella digital permanece única en ambos navegadores y en Chrome no se aplicaron directivas equivalentes de bloqueo de extensiones ni de DNS cifrado; asimismo, convendría imponer una versión mínima de TLS por política. Aun así, el perfil resultante es restrictivo y adecuado para un entorno corporativo.

4. Auditoría de sistema móvil (BYOD)

4.1. Metodología y herramientas

Se auditó un dispositivo **Android (Samsung SM-A546B, Android 16)** aplicando la checklist A/B de la política corporativa. Para el análisis se utilizaron herramientas de código abierto y gratuitas: **Malwarebytes** (puntuación de protección y malware), **Koodous** (análisis de APKs), **Root Checker** (integridad del sistema) y **PCAPdroid** (monitorización de conexiones en segundo plano por aplicación, en sustitución de NetGuard). La información del sistema y la verificación de integridad se recogen en el Anexo B (Fig. B.11 y B.12).

4.2. Resultados por checklist

Checklist A (controles básicos). El dispositivo cuenta con el parche de seguridad de octubre de 2026 y SELinux en modo *Enforcing*, y Root Checker confirmó la ausencia de acceso root. Los permisos de instalación desde orígenes desconocidos están correctamente desactivados para todas las aplicaciones (Anexo B, Fig. B.13). Como riesgo inicial, el dispositivo tenía guardadas **81 redes Wi-Fi**, incluyendo redes públicas abiertas (Anexo B, Fig. B.14); como corrección se eliminaron todas las innecesarias. El Bluetooth se mantiene desactivado cuando no se utiliza.

Checklist B (controles avanzados). La puntuación inicial de Malwarebytes fue de **38 (Deficiente)**, motivada por el exceso de permisos y la configuración del sistema, sin detección de malware en Koodous (Anexo B, Fig. B.15 y B.16). Se revisó el gestor de permisos y se revocó el permiso de «Dispositivos cercanos» (99 aplicaciones) y los de micrófono y ubicación a terceros no esenciales. La monitorización con PCAPdroid mostró únicamente conexiones legítimas (NTP, Google Play Services y telemetría del propio antivirus), sin comunicaciones a servidores de Comando y Control (Anexo B, Fig. B.19–B.21). Tras las correcciones, la puntuación ascendió a **88 (Bien)** (Anexo B, Fig. B.17 y B.18).

4.3. Conclusiones

La auditoría redujo de forma notable la superficie de ataque del dispositivo: la puntuación de protección se incrementó en 50 puntos (de 38 a 88), métrica orientativa de la herramienta. La eliminación de las 81 redes Wi-Fi guardadas reduce la exposición a ataques de red como *Evil Twin*, y la revisión de permisos críticos limita la exfiltración de datos por terceros. Los análisis de Koodous y PCAPdroid no mostraron malware ni comunicaciones con servidores de C2 durante el periodo analizado, si bien una captura puntual no permite descartar por completo un *beaconing* ocasional.

5. Auditoría de sistema web

5.1. Descripción del sistema y herramientas

La auditoría de las aplicaciones web se realizó sobre un entorno de laboratorio aislado desplegado con Docker, sin impacto sobre producción. Se emplearon **DVWA** (objetivo principal, `127.0.0.1:8080`, en nivel *low* para explotación y *high/impossible* para verificar mitigaciones) y **OWASP Juice Shop** (apoyo, `127.0.0.1:3001`), ambas expuestas solo en loopback (Anexo C, Fig. C.1). Como motor DAST y proxy de interceptación se utilizó **OWASP ZAP 2.17**, con un perfil de Firefox enrutado al proxy local `127.0.0.1:8081` y la CA raíz de ZAP importada para el tráfico HTTPS. El *fuzzing* se alimentó de diccionarios propios de SQLi, XSS y Path Traversal.

5.2. Plan de pruebas y resultados

Trazabilidad del tráfico HTTP/HTTPS. Con ZAP en modo estándar se navegó por HTTP y HTTPS; el panel *History* registra todas las peticiones y respuestas de forma íntegra, sin modificar ningún parámetro (Anexo C, Fig. C.4 y C.5). La inspección del certificado confirma su reemisión por la CA de ZAP, prueba de la interceptación del tráfico cifrado de extremo a extremo (Fig. C.2, C.3 y C.6). De forma diferenciada, mediante un punto de interrupción se interceptó una petición de autenticación y se alteró el parámetro `password` antes de reenviarla, ilustrando un escenario Man-in-the-Middle (Fig. C.7).

Explotación de vulnerabilidades (OWASP Top 10 2025). Sobre el parámetro `id` de DVWA, el Fuzzer con 26 cargas marcó como *Reflected* las cadenas `' OR '1'='1` (mayor tamaño de respuesta) y confirmó inyección ciega con las variantes `SLEEP(5)` (2–3 s de respuesta); la explotación manual volcó la tabla de usuarios con sus hashes MD5 sin salt (Fig. C.8 y C.9). En XSS, la carga `<script>alert(1)</script>` se ejecuta de forma reflejada y `<img src=x onerror=alert(1)>` de forma almacenada y persistente (Fig. C.10 y C.11). En File Inclusion, la petición `?page=/etc/passwd` devuelve ficheros arbitrarios del servidor (Fig. C.12). El escaneo activo generó 37 alertas adicionales (ausencia de anti-CSRF, CSP débil, cookies sin flags), clasificables como A02 (Fig. C.13).

Vulnerabilidad	OWASP 2025	Mitigación propuesta
Inyección SQL	A05 – Injection	Consultas parametrizadas, mínimo privilegio en BD, sin concatenar entrada.
XSS reflejado y almacenado	A05 – Injection	Codificación de salida contextual, validación, CSP y cookies HttpOnly.
Path Traversal / LFI	A01 – Broken Access Control	Lista blanca de ficheros, canonicalización de rutas y directorio base restringido.
Cabeceras de seguridad ausentes	A02 – Security Misconfiguration	HSTS, CSP, X-Frame-Options y X-Content-Type-Options.

5.3. Conclusiones

La auditoría dinámica demostró la trazabilidad íntegra del tráfico HTTP y HTTPS a través del proxy interceptor, así como su capacidad de interceptación activa. Sobre la aplicación de laboratorio se verificaron tres vulnerabilidades explotables del OWASP Top 10 2025 (Injection en SQLi y XSS, y Broken Access Control vía Path Traversal), con evidencia reproducible y plan de mitigación. La verificación de las contramedidas elevando el nivel de seguridad de la aplicación confirma que el origen reside en una validación de entrada y codificación de salida deficientes, no en la plataforma.

6. Referencias

1. OWASP Foundation. *OWASP Top 10:2025*. https://owasp.org/Top10/
2. Center for Internet Security. *CIS Benchmarks*. https://www.cisecurity.org/cis-benchmarks
3. NIST. *SP 800-115: Technical Guide to Information Security Testing and Assessment*.
4. Centro Criptológico Nacional. *Esquema Nacional de Seguridad (ENS)*. https://www.ccn-cert.cni.es
5. CISOfy. *Lynis – Security auditing tool for Unix/Linux*. https://cisofy.com/lynis/
6. OWASP Foundation. *OWASP Zed Attack Proxy (ZAP)*. https://www.zaproxy.org
7. DVWA. *Damn Vulnerable Web Application*. https://github.com/digininja/DVWA
8. OWASP Foundation. *OWASP Juice Shop*. https://owasp.org/www-project-juice-shop/
9. Electronic Frontier Foundation. *Cover Your Tracks*. https://coveryourtracks.eff.org
10. Qualys SSL Labs. *SSL Client Test*. https://www.ssllabs.com/ssltest/viewMyClient.html
11. Malwarebytes. *Malwarebytes Mobile Security*. https://www.malwarebytes.com
12. Koodous. *Android APK analysis platform*. https://koodous.com

Anexo A. Evidencias de endpoints Linux (Lynis)

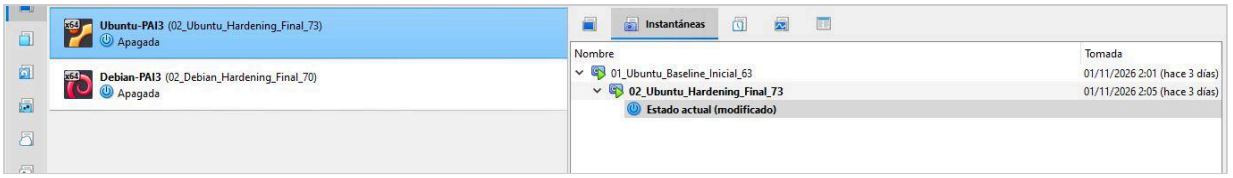


Fig. A.1. Árbol de instantáneas de Ubuntu-PAI3 en VirtualBox (Baseline 63, Hardening Final 73).

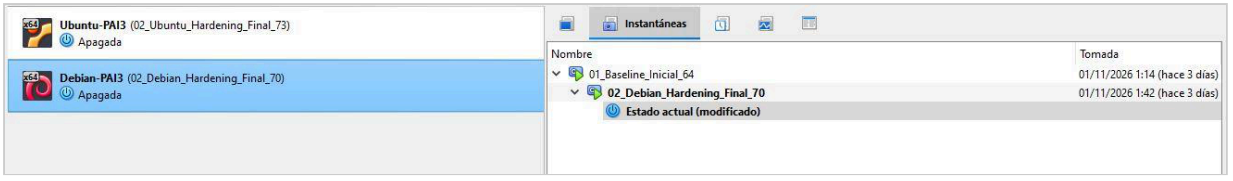


Fig. A.2. Árbol de instantáneas de Debian-PAI3 en VirtualBox (Baseline 64, Hardening Final 70).

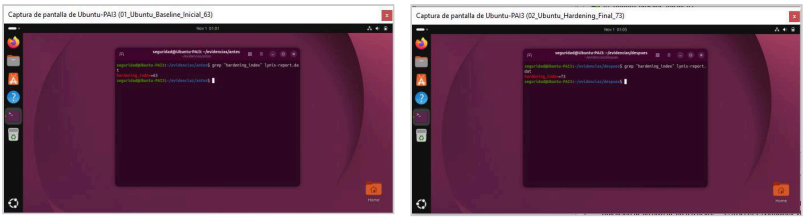


Fig. A.3 y A.4. Lynis en Ubuntu 24.04: Hardening Index inicial (63) y final (73).

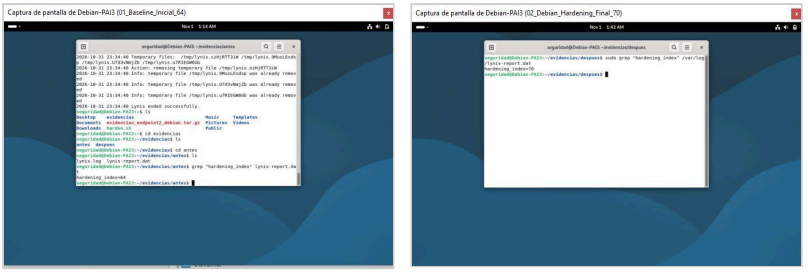


Fig. A.5 y A.6. Lynis en Debian 12: Hardening Index inicial (64) y final (70).

Anexo B. Evidencias de navegadores y dispositivo móvil

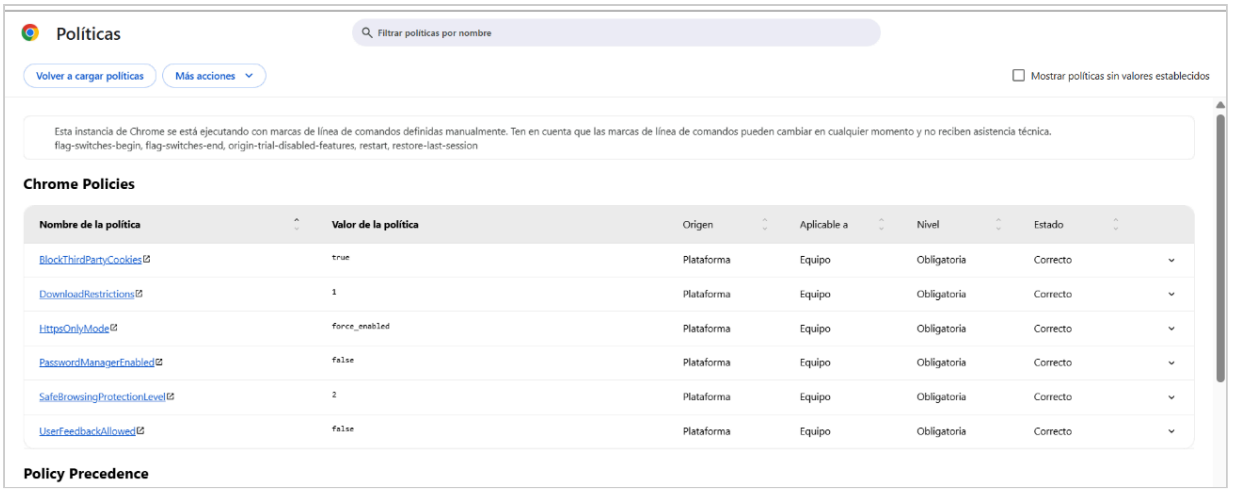


Fig. B.1. Políticas aplicadas en Chrome (chrome://policy).

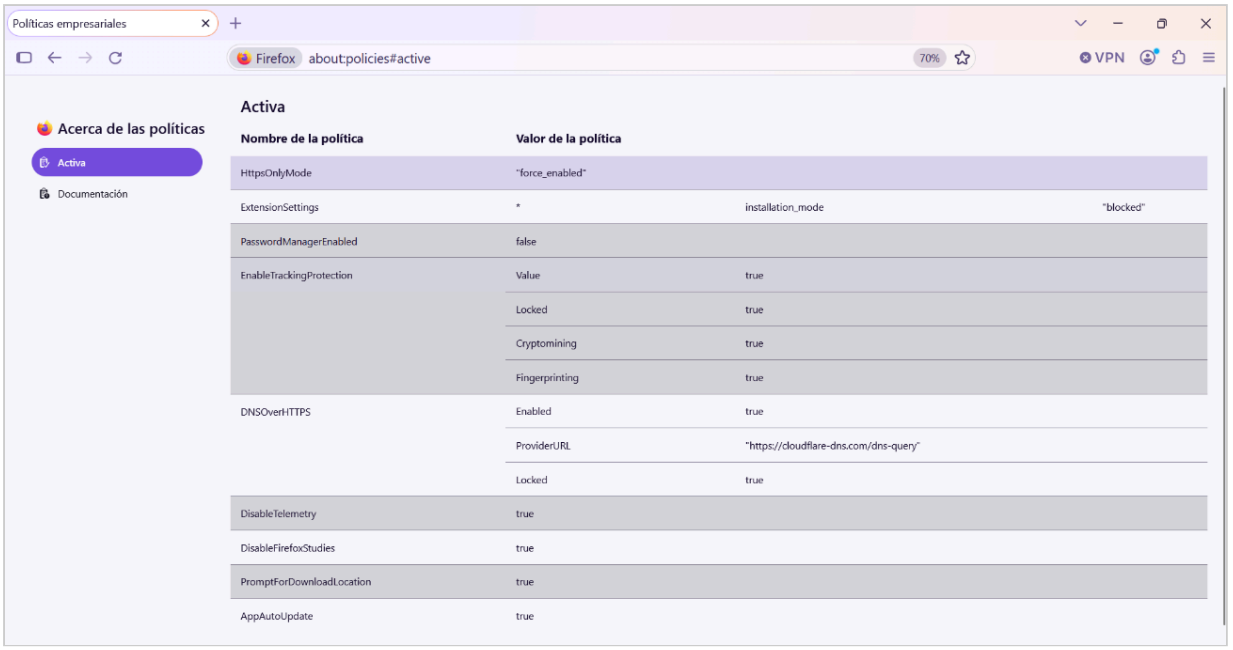
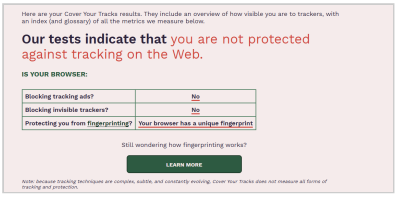


Fig. B.2. Políticas aplicadas en Firefox (about:policies).



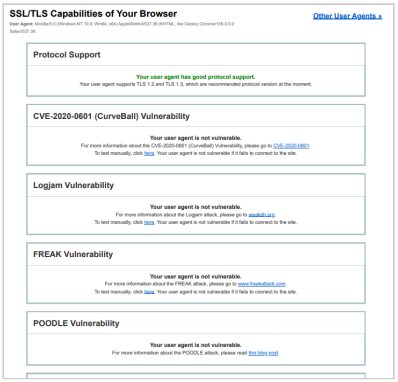
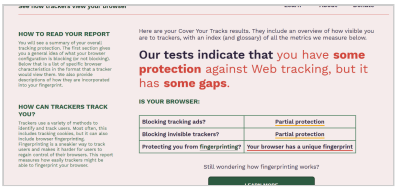


Fig. B.3 y B.4. Chrome antes del bastionado: EFF Cover Your Tracks y SSL Labs Client Test.



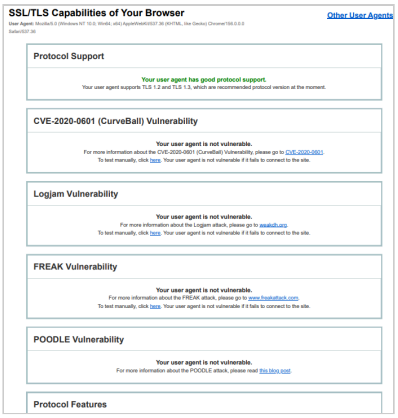
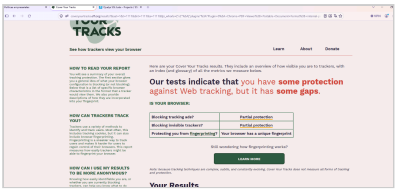


Fig. B.5 y B.6. Chrome después del bastionado: EFF Cover Your Tracks y SSL Labs Client Test.



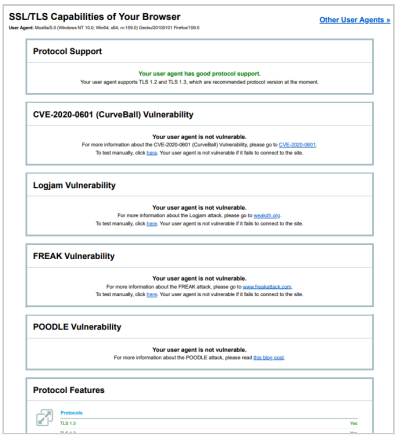
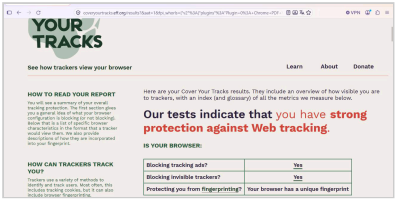


Fig. B.7 y B.8. Firefox antes del bastionado: EFF Cover Your Tracks y SSL Labs Client Test.



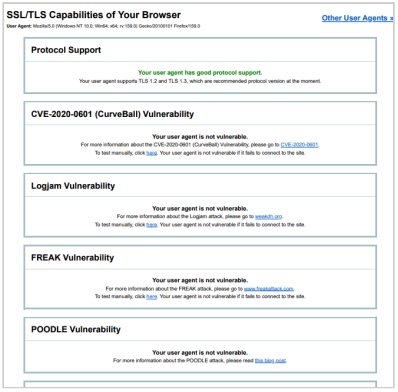


Fig. B.9 y B.10. Firefox después del bastionado: EFF Cover Your Tracks y SSL Labs Client Test.

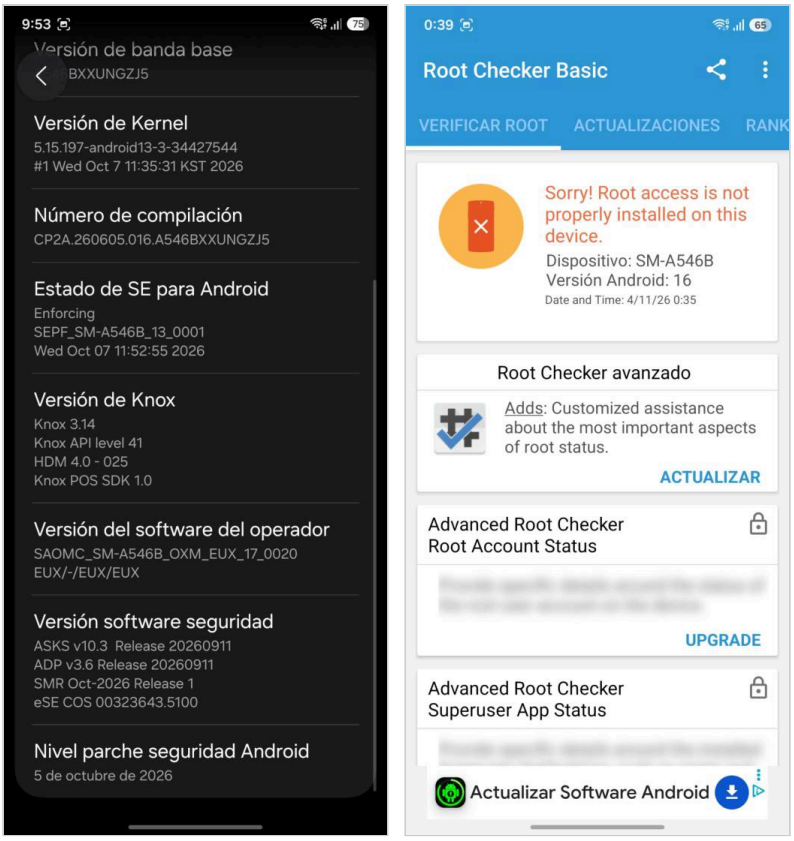


Fig. B.11 y B.12. Información del sistema y comprobación de integridad con Root Checker.

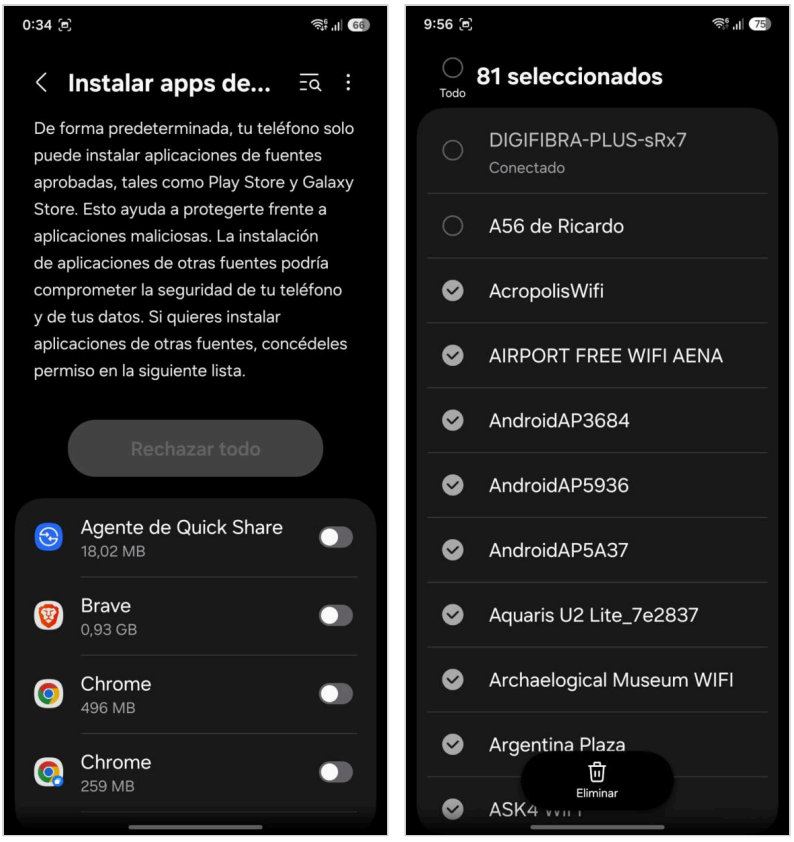


Fig. B.13 y B.14. Instalación de apps desconocidas desactivada y redes Wi-Fi guardadas (81).

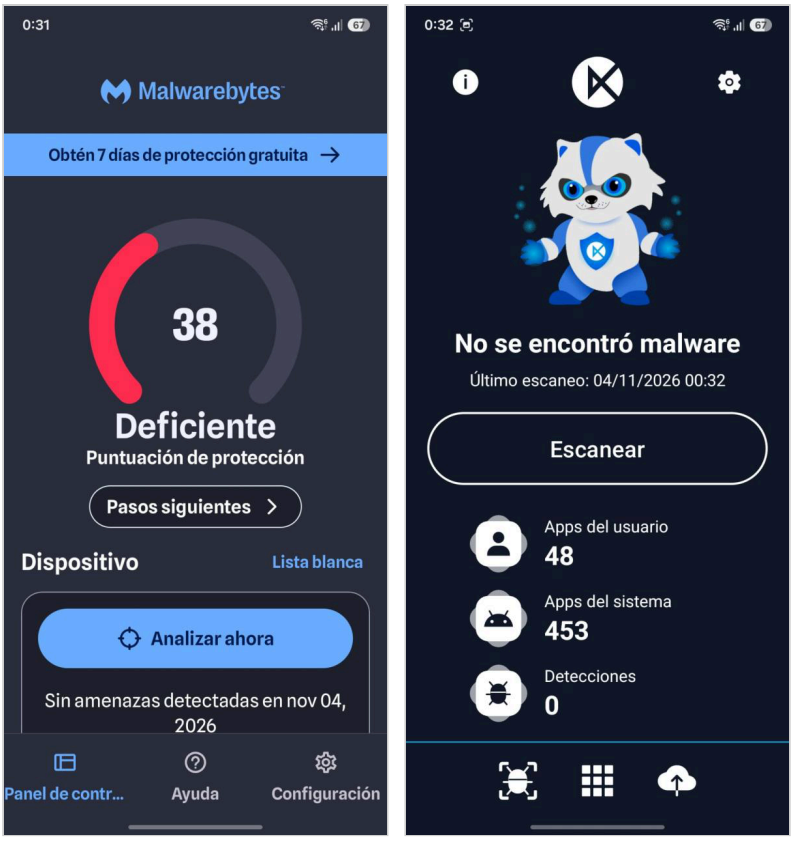


Fig. B.15 y B.16. Malwarebytes antes de las correcciones (puntuación 38) y escaneo de Koodous.

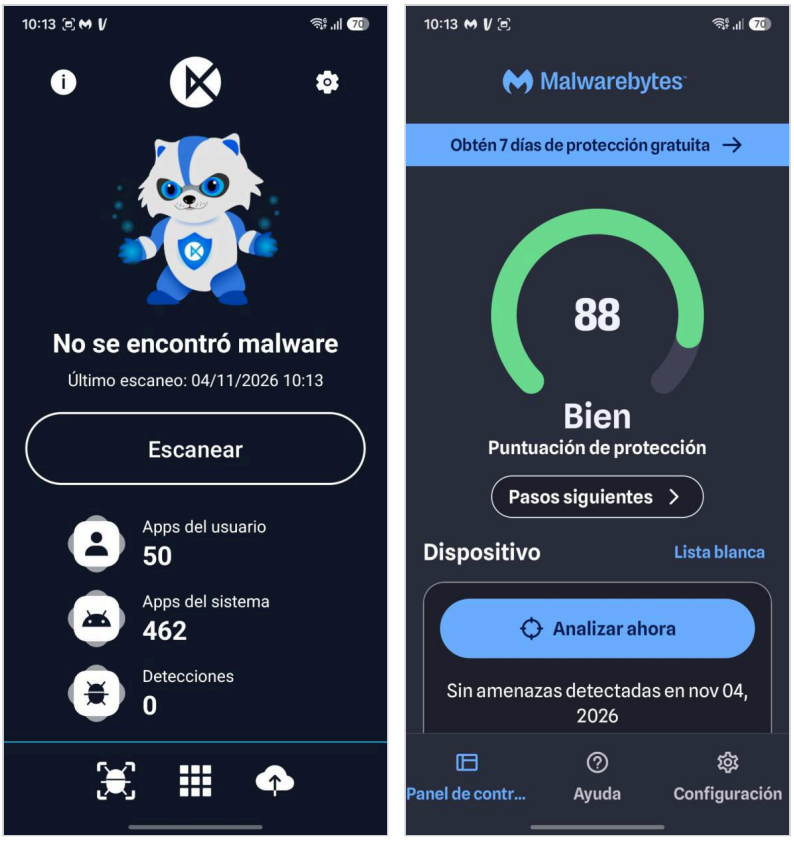


Fig. B.17 y B.18. Malwarebytes después de las correcciones (puntuación 88).

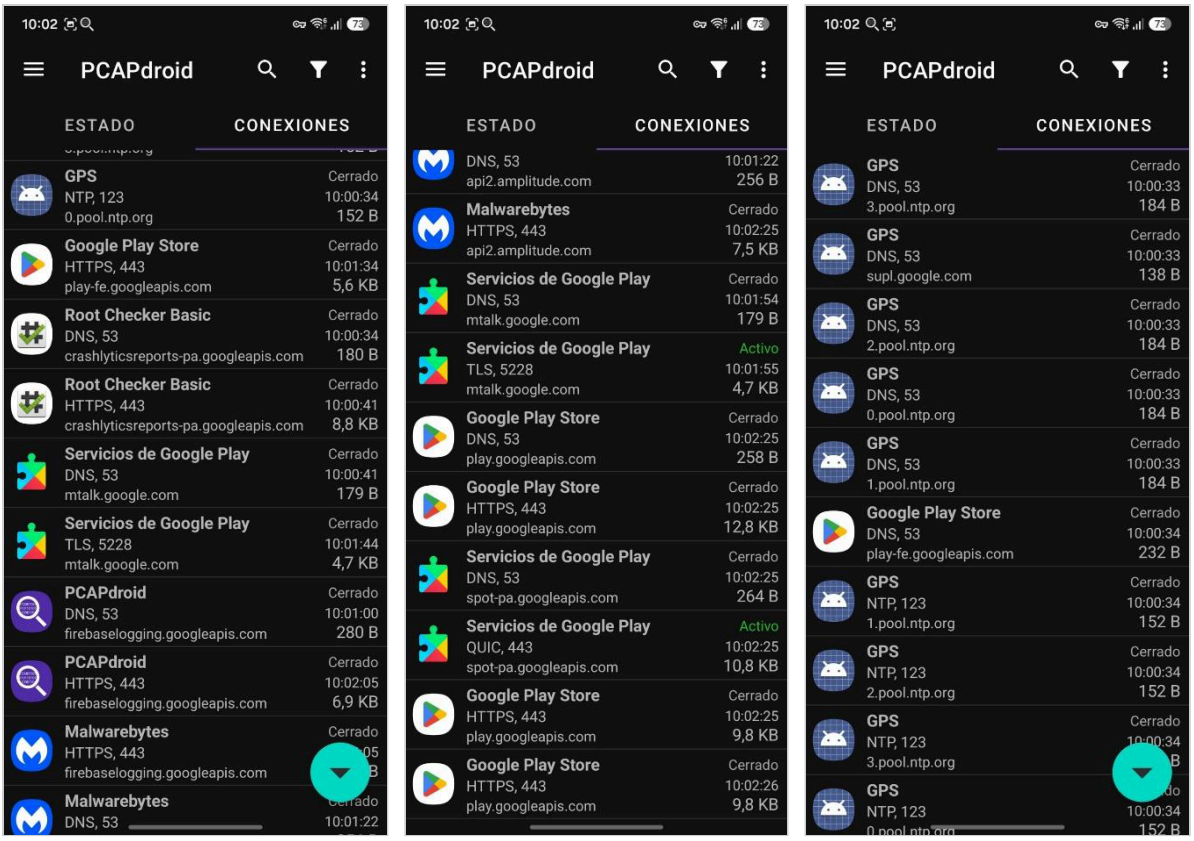


Fig. B.19 a B.21. Monitorización de conexiones en segundo plano con PCAPdroid.

Anexo C. Evidencias de auditoría web (OWASP ZAP)

```
PS C:\Users\franr\JAVI\Universidad\26-27\Primer Cuatri\SSII\PAI\PAIS\PAI3\Evidencias_Tecnicas\04_Auditoria_Sistema_We> d
ocker compose ps
NAME                IMAGE                              COMMAND                  SERVICE     CREATED              STATUS
          PORTS
vulnaweb-dvwa       vulnerables/web-dvwa:latest        "/main.sh"               dvwa        About a minute ago   Up About a
 minute   127.0.0.1:8080->80/tcp
vulnaweb-juiceshop  bkimminich/juice-shop:latest       "/nodejs/bin/node /j…"   juiceshop   About a minute ago   Up About a
 minute   127.0.0.1:3001->3000/tcp
```

Fig. C.1. Laboratorio desplegado con Docker Compose (DVWA 8080, Juice Shop 3001).

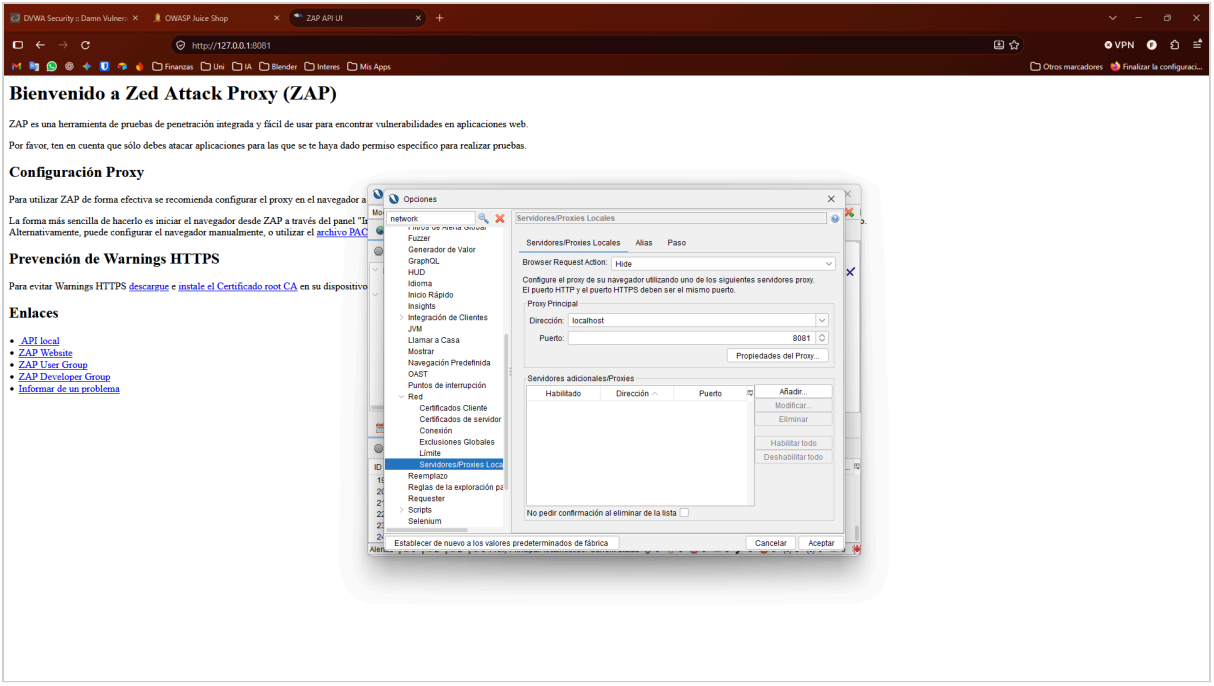


Fig. C.2. Configuración del proxy de ZAP y del navegador.

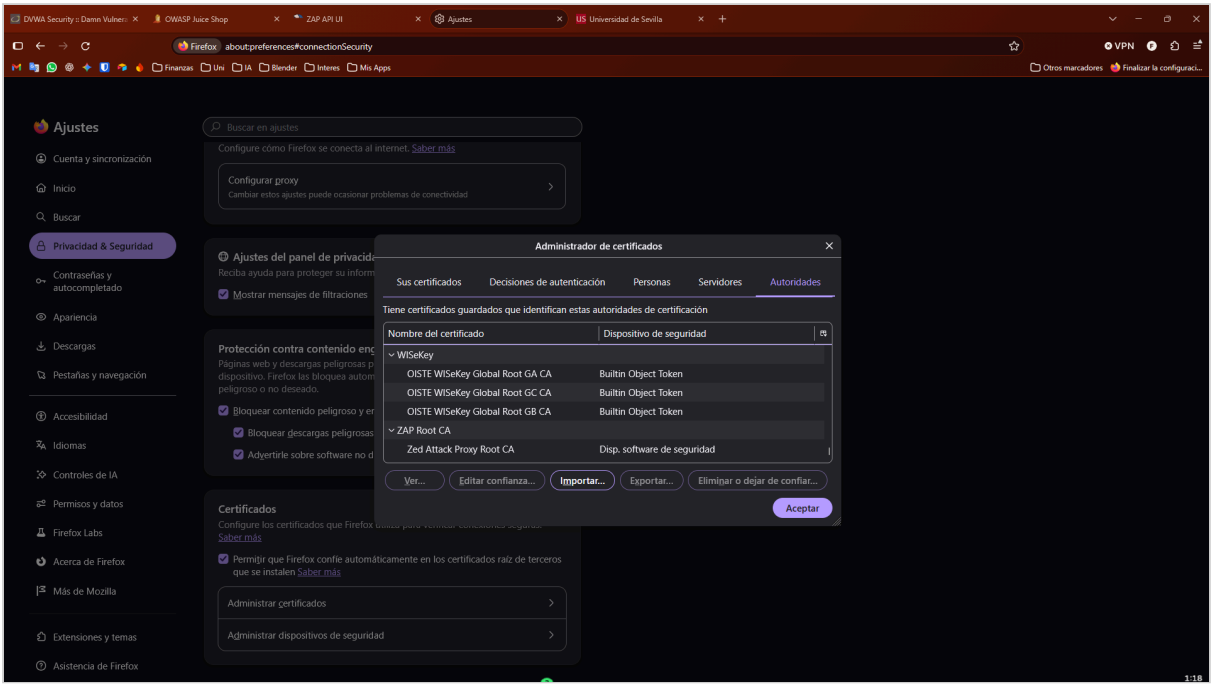


Fig. C.3. CA raíz de ZAP importada en el almacén de Autoridades de Firefox.

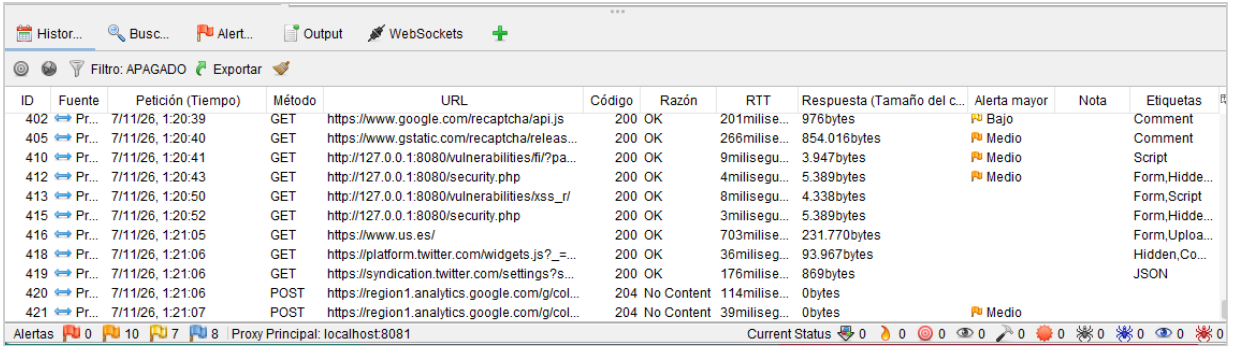


Fig. C.4. Panel History: trazabilidad simultánea de HTTP y HTTPS sin modificación.

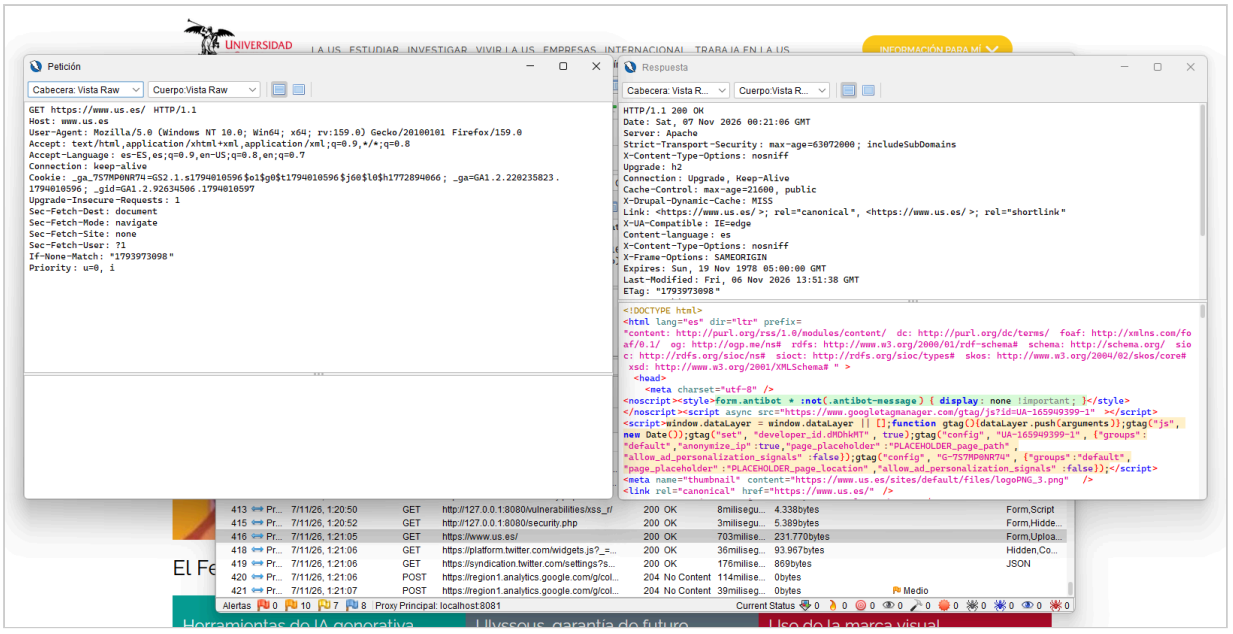


Fig. C.5. Petición y respuesta HTTPS completas trazadas a través del proxy.

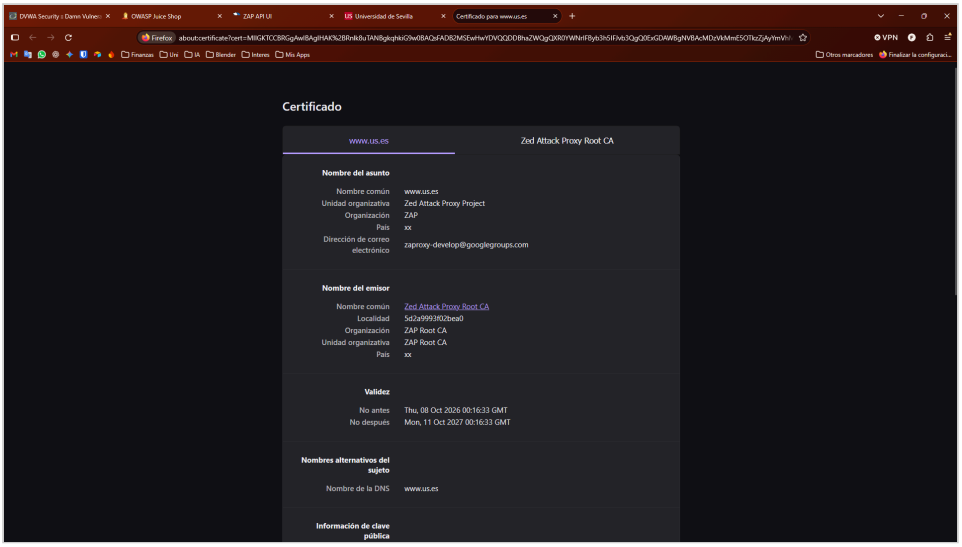


Fig. C.6. Certificado reemitido por la CA de ZAP (interceptación del tráfico cifrado).

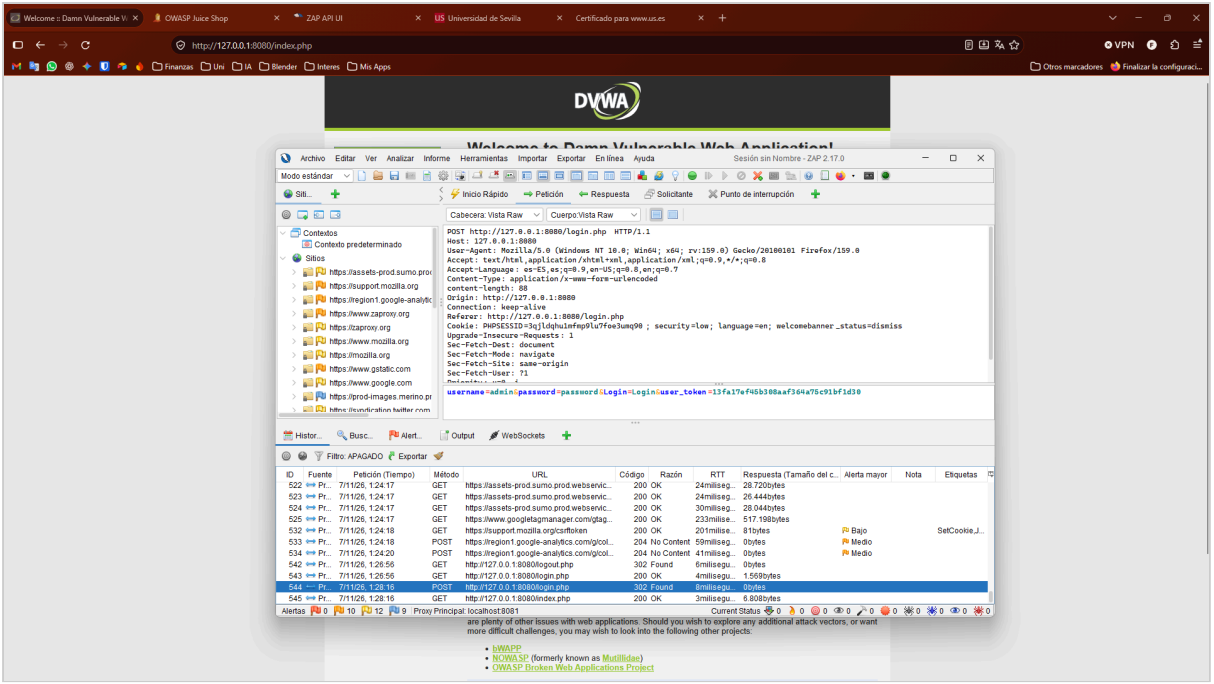


Fig. C.7. Petición de autenticación interceptada mediante breakpoint (MitM).

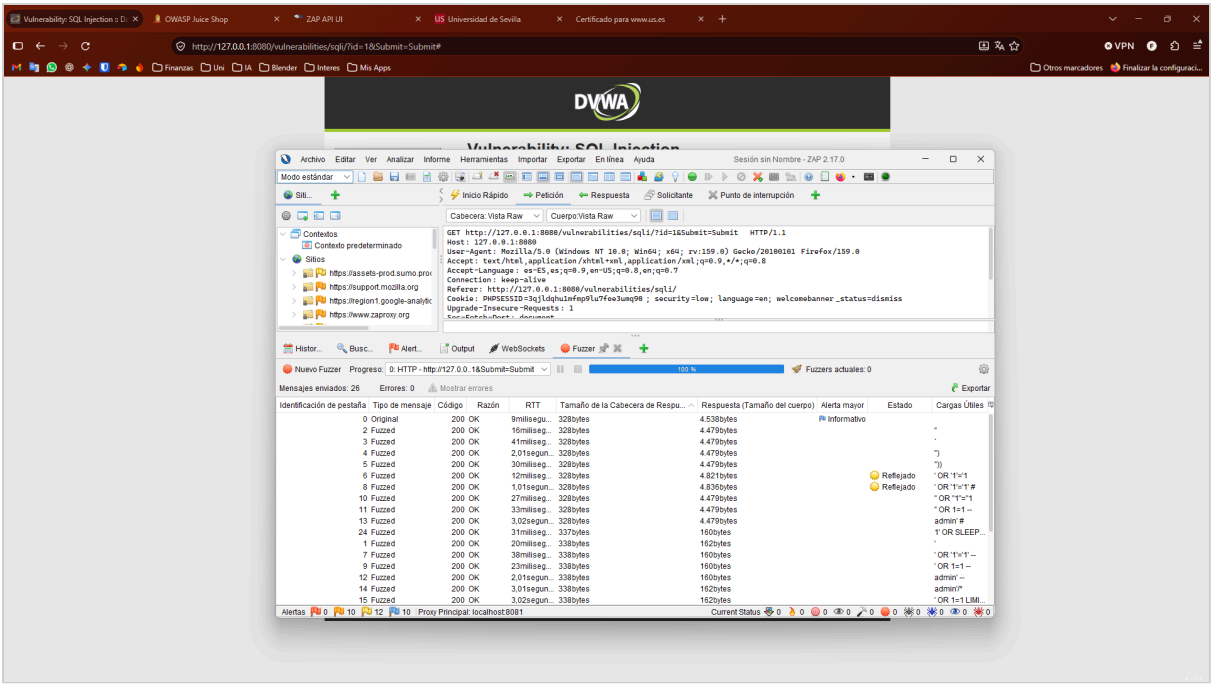


Fig. C.8. Resultados del Fuzzer de inyección SQL (cargas Reflected y basadas en tiempo).

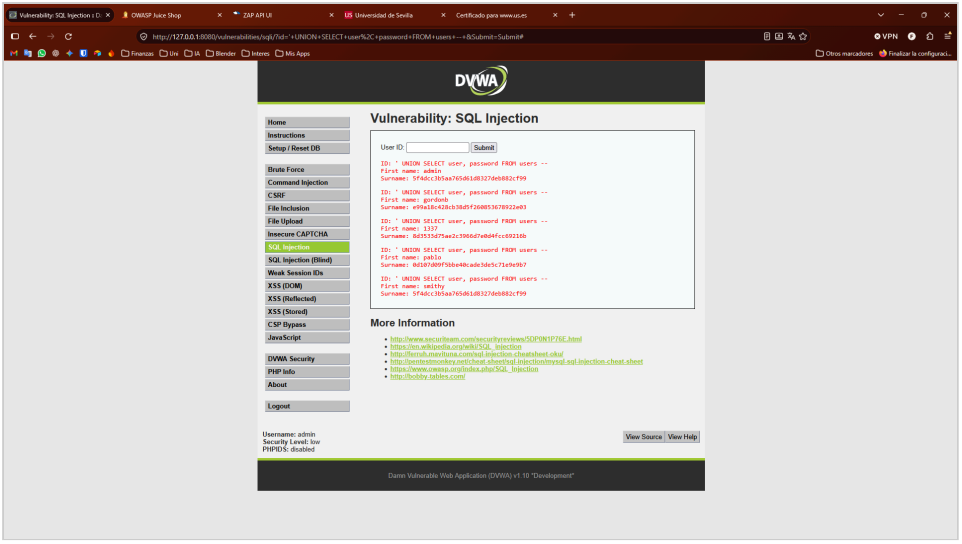


Fig. C.9. Volcado de la tabla de usuarios y hashes mediante inyección UNION.

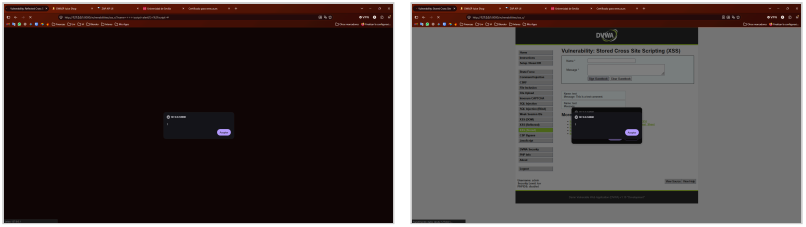


Fig. C.10 y C.11. XSS reflejado y XSS almacenado ejecutándose en la aplicación.

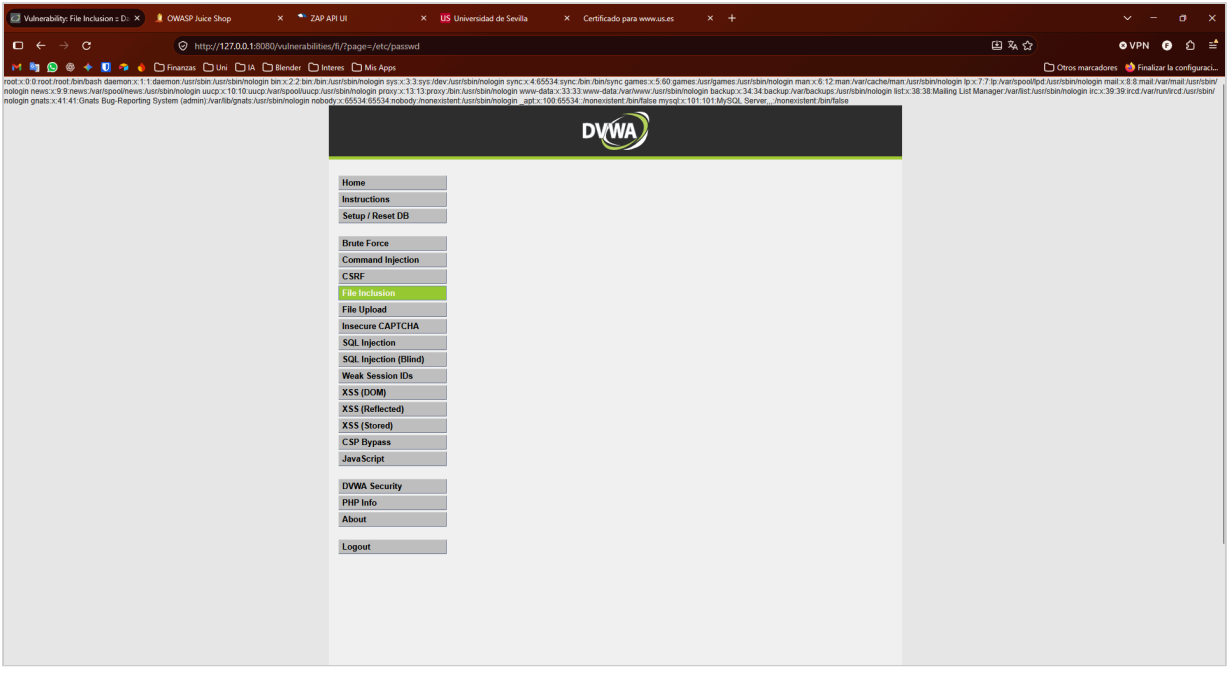


Fig. C.12. Lectura de /etc/passwd mediante inclusión de ficheros (Path Traversal).

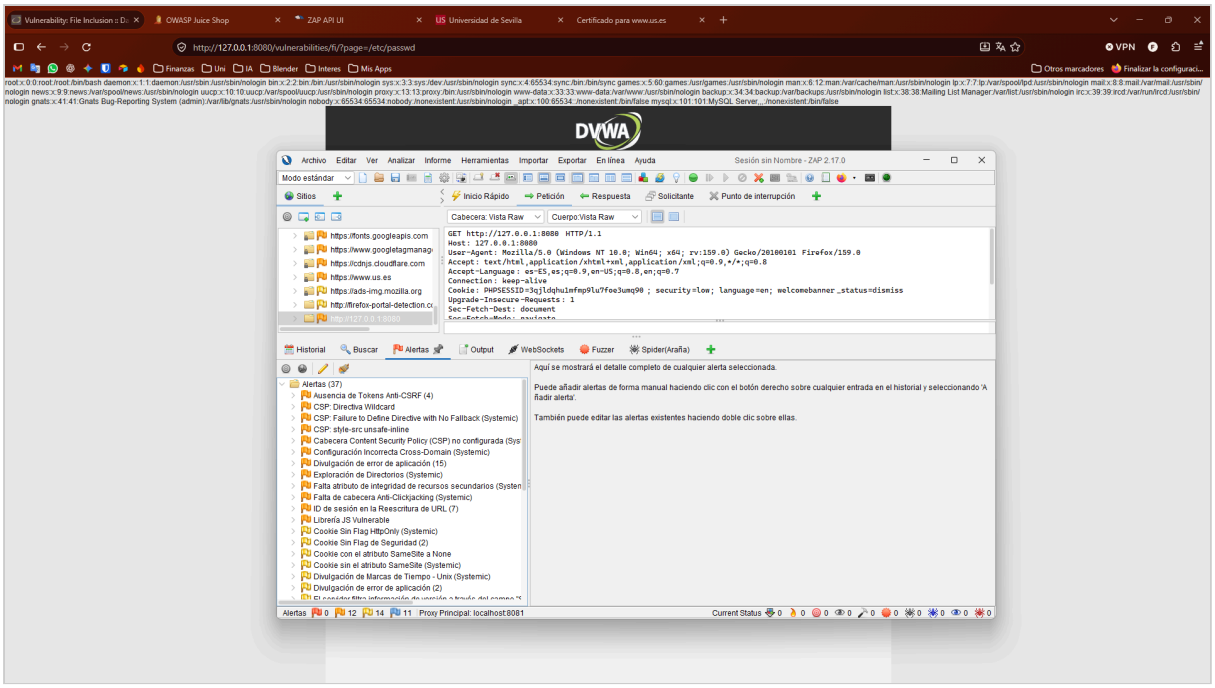


Fig. C.13. Panel de alertas de ZAP con las 37 incidencias del escaneo activo.